Experiment No. 3

Perform Session Hijacking Using Various Tools

AIM

To understand and demonstrate session hijacking by intercepting and taking over an active, valid session between a client and a web server in a controlled lab environment, using tools such as Burp Suite and OWASP ZAP.

PROCEDURE

1. Set up a controlled lab environment with an attacker machine and a victim machine on the same isolated network, along with a vulnerable test web application.
2. Configure the browser on the victim machine to route traffic through a proxy tool (Burp Suite / OWASP ZAP) running on the attacker machine.
3. Have the victim log in to the test web application; capture the HTTP request/response traffic using the proxy tool's interception feature.
4. Identify the session cookie / session ID (e.g., PHPSESSID, JSESSIONID) from the captured traffic.
5. On the attacker machine, open the same web application and use the browser's developer tools or a cookie-editor extension to replace the current session cookie with the captured victim session ID.
6. Reload the application on the attacker machine and observe whether the attacker is now authenticated as the victim (i.e., the session has been hijacked).
7. Document each captured packet, the cookie value used, and the resulting access gained.

SAMPLE OUTPUT

```
Burp Suite HTTP History - Intercepted Request:
GET /dashboard HTTP/1.1
Host: testapp.local
Cookie: PHPSESSID=8f14e45fceea167a5a36dedd4bea2543

Attacker browser cookie before hijack:
  PHPSESSID=1a79a4d60de6718e8e5b326e338ae533 (unauthenticated)

Cookie replaced with captured session ID and page reloaded:
  PHPSESSID=8f14e45fceea167a5a36dedd4bea2543

Result: /dashboard loaded showing 'Welcome, victim_user' -
attacker successfully accessed the victim's authenticated session.
```

RESULT

Session hijacking was successfully demonstrated in the lab environment by capturing a valid session cookie using Burp Suite/OWASP ZAP and reusing it to gain unauthorized access to the victim's authenticated session, highlighting the risk of unencrypted or improperly secured session tokens.